

Plano de Mitigação de Riscos – Sistema de E-commerce

Documento contendo: 1) Exemplo preenchido 2) Template para uso futuro

Parte 1 – Exemplo Preenchido

1. Visão Geral

Este plano define ações de mitigação e contingência para os principais riscos de um sistema de e-commerce, visando reduzir impactos em disponibilidade, performance, segurança, pagamentos, fraude, logística e conformidade.

Sistema	E-commerce Loja Nova Era
Patrocinador	Diretoria Executiva
Responsável	Gerente de Tecnologia
Data	15/03/2026
Versão	1.0

2. Critérios de Severidade (RAG)

-  Verde – risco controlado, sem impacto relevante.
-  Amarelo – atenção necessária, plano de ação em andamento.
-  Vermelho – impacto crítico, ação imediata necessária.

3. Principais Riscos e Planos de Mitigação

Risco	Prob.	Impacto	RAG	Mitigação	Contingência
Indisponibilidade do site em picos de acesso	Alta	Alto		Auto-scaling, CDN, testes de carga trimestrais.	Modo degradado e página de contingência.
Falha no gateway de pagamento	Média	Alto		Multi-PSP e monitoramento de autorização.	Redirecionar para PIX/Boleto e PSP secundário.
Fraude em pagamentos	Média	Alto		Antifraude com score dinâmico e 3DS.	Bloqueio de BIN/CEP e revisão manual.
Ataques de segurança (DDoS, XSS)	Baixa	Crítico		WAF, rate limit, SAST/DAST.	Ativação de plano de resposta a incidentes.
Atraso logístico/transportadora	Média	Médio		Múltiplas transportadoras e SLA por região.	Troca automática de operador e comunicação

4. Papéis e Responsabilidades (RACI)

- Tecnologia: responsável pela mitigação técnica e monitoramento.
- Operações: responsável por logística e atendimento ao cliente.
- Financeiro/Risco: responsável por pagamentos e fraude.
- Jurídico/Compliance: responsável por LGPD e conformidade.

5. Monitoramento e KPIs

- Uptime da plataforma (%)
- p95 de latência do checkout
- Taxa de erro de pagamento (%)
- Chargeback (%)
- OTIF – entregas no prazo (%)

Parte 2 – Template de Plano de Mitigação

1. Identificação

Sistema / Projeto
Patrocinador
Responsável
Data
Versão

2. Critérios de Severidade (RAG)

 Verde –

 Amarelo –

 Vermelho –

3. Matriz de Riscos

Risco	Prob.	Impacto	RAG	Mitigação	Contingência

4. Planos de Ação / Playbooks

Cenário:

Gatilhos:

Ações imediatas (0–15 min):

Ações corretivas (15–60 min):

Comunicação:

Responsável:

5. KPIs de Monitoramento

KPI | Definição | Meta | Frequência | Responsável

6. Aprovação e Controle de Versão

Versão | Data | Descrição da Mudança | Aprovador